ABSTRACT

Generating Secure and High-Quality Code with LLMs by Combining CWE Vulnerability Knowledge and Business Logic Understanding

Department of Information Technology

The widespread adoption of large language models (LLMs) for automated code generation has fundamentally transformed software development, yet recent large-scale empirical evaluations reveal that this convenience comes at a persistent security cost. A comprehensive multi-language, multi-model measurement study spanning five widely used LLMs (Claude-3.5, GPT-4o, Gemini-1.5, Codestral, and Llama-3) across four programming languages found that AI-generated code continues to exhibit recurring, language-specific security weaknesses including improper cryptographic implementation, hardcoded credentials, and memory-safety violations with models frequently failing to utilize modern secure language features even when readily available. While CWE-guided mitigation frameworks have demonstrated meaningful reductions in vulnerability rates by retrieving relevant weakness knowledge and steering generation toward safer implementations, such approaches remain narrow in scope, validated on a limited set of languages and vulnerability types, and largely agnostic to the functional business context and organization-specific security expectations that govern real-world software systems; moreover, existing research shows that LLM-generated code security can further degrade rather than improve across iterative, multi-turn refinement, undermining confidence in AI-assisted development workflows. To address these gaps, this project proposes a unified, single-pass secure code generation framework that jointly reasons over structured CWE vulnerability knowledge, language-specific secure coding idioms, and the inferred business logic and functional intent underlying a given development task, with the broader aim of producing code that is simultaneously secure, high-quality, and aligned with real-world development requirements without relying on repeated prompting or post-hoc correction. By grounding secure code generation in both established vulnerability taxonomies and the practical context in which code is actually written and deployed, this work aims to move beyond treating security as an afterthought in AI-assisted development, and instead establish it as an integral, context-sensitive property of the generation process itself.

Keywords

Large Language Models (LLMs), Secure Code Generation, Common Weakness Enumeration (CWE), Business Logic Understanding, AI-Assisted Software Development, Code Security

Team Members

160123737048 – Manda Bharath Kumar

160123737067 – Dileep Yarrabothula

160123737301 – Sai Prakash Avula

Under the Guidance of

Dr. M Venu Gopalachari, Professor

Dept of Information Technology Signature of Guide